

STHITAPRAJNA BISWAL

Cloud Security Expert · Application VAPT Specialist · AppSec Professional · Red Team Practitioner

+91-9078225080 | sthitiswal2002@gmail.com | [LinkedIn](#) | Bhubaneswar, India

PROFESSIONAL SUMMARY

Cybersecurity Expert with 2+ years delivering measurable risk reduction across web applications, REST/SOAP APIs, mobile apps, cloud, and Kubernetes environments in FinTech. Executed **50+ end-to-end penetration tests** - identifying 230+ unique vulnerabilities (IDOR, auth bypass, injection, business logic, broken access controls) using **Burp Suite Pro and Nessus** as primary tooling. Delivered PCI DSS v4.0.1, ISO 27001:2022, and SOC 2 Type 2 audits for clients including NPCI, UIDAI, Indus Bank, UCO Bank, Bank of Baroda, Axis Bank, and Kotak Mahindra. Deep expertise in exploit chain development, PoC-backed reporting, threat modeling, and AppSec architecture aligned to OWASP Top 10, MITRE ATT&CK, and PTES.

CORE COMPETENCIES

Web Application VAPT	REST / SOAP API Security	Mobile App Penetration Testing	AppSec & PoC Writing
Burp Suite Pro & Nessus	Cloud Attack Surface (GCP/AWS)	Kubernetes & Container Security	OWASP and MITRE ATT&CK
Red Team & Adversary Simulation	OSINT & External Recon	PCI DSS v4.0.1 · ISO 27001:2022 · SOC 2	Security Automation (Python / Bash)

PROFESSIONAL EXPERIENCE

Information Security Engineer / Penetration Tester

iServeU Technology Pvt. Ltd. Bhubaneswar, India

Dec 2023 – Present

APPLICATION VAPT - PRIMARY FOCUS AREA

- Web Application VAPT (Burp Suite Pro · Flagship Tool):** Led 50+ full-scope web application penetration tests against FinTech, BFSI, and payment platforms using Burp Suite Pro as the primary proxy and exploitation engine - uncovered 200+ unique vulnerabilities including IDOR, auth bypass, session fixation, reflected/stored XSS, SQL injection, XXE, SSRF, CSRF, and broken access controls; every engagement closed with exploit-backed PoC reports and remediation playbooks aligned to OWASP Top 10.
- REST & SOAP API Penetration Testing:** Performed targeted API security assessments on BBPS, UPI, and payment gateway integrations - validated auth flows, token handling, rate-limiting, broken object-level authorisation (BOLA/IDOR), mass assignment, and business logic flaws using Burp Suite Pro with custom Intruder/Repeater payloads; identified and closed 12 critical/high findings in IndusInd Bank API integrations within a 3-week window ahead of compliance deadline.
- Mobile Application Security Testing:** Executed Android and iOS VAPT covering insecure data storage, improper session management, reverse engineering, traffic interception via Burp Suite Pro, and certificate pinning bypass - uncovered deep-linked injection paths and insecure API calls across mobile payment apps deployed to millions of end-users.
- AppSec Architecture & Threat Modeling:** Delivered threat-aware architecture reviews and data-flow diagrams (DFDs) for 8 payment platforms - mapped 40+ design-level attack vectors across trust boundaries and authentication flows; recommendations adopted by engineering teams reduced architecture-level findings in subsequent VAPT cycles by ~55%.
- Vulnerability Scanning & Triage - Nessus:** Deployed and tuned Nessus across GKE nodes, containerised workloads, and 200+ internal GCP services - identified 38 critical/high CVEs across 15+ services; triaged, prioritised by exploitability and business impact, and coordinated full critical CVE closure within 30 days; reduced overall container attack surface by ~72%.

- **Data Exposure, DLP & Injection Chains:** Discovered PAN and Aadhaar exposure across 6 legacy banking endpoints and 3 misconfigured Cloud Storage buckets; constructed end-to-end exfiltration PoC chains; led a Google DLP API implementation (Python 3.10) classifying and masking PCI/PII data across 500+ daily transactions at scale.

CLOUD, INFRASTRUCTURE & ADVERSARIAL OPS

- **Cloud Attack Surface Reduction (GCP/AWS):** Enumerated and exploited misconfigurations across 92+ GCP Cloud Storage buckets and over-privileged IAM roles exposing sensitive payment data; led end-to-end hardening (private bucket enforcement, IAM least-privilege, CMEK) that eliminated 100% of identified public exposure paths with zero production outages.
- **Internal Infrastructure VAPT:** Conducted internal VAPT of GCP compute instances, VMs, and Kubernetes nodes uncovered 3 privilege escalation paths and 5 lateral movement vectors across production segments; proposed network segmentation and service hardening controls implemented across 200+ internal services.
- **Red Team / Cloud Threat Emulation:** Led red-team-style investigation of a live cryptojacking incident, traced initial access, 2 persistence mechanisms (malicious cron/systemd), and crypto-mining payload; designed post-engagement hardening and 6 new Wazuh detection rules cutting MTTD for similar attacks by ~80%.
- **Protocol Abuse - MQTT/IoT:** Identified unauthenticated MQTT broker in AWS-based payment services capable of manipulating live financial transactions; built working PoC demonstrating the full attack chain; drove broker hardening (mTLS, ACLs, auth enforcement) across 4 payment microservices before any regulatory review.
- **Wireless Penetration Testing:** Executed wireless security assessments identifying WEP/WPA weaknesses and 4 rogue access points across campus networks adjacent to payment infrastructure; validated WPA3 migration and VLAN-based segmentation, fully isolating payment systems from corporate traffic.
- **OSINT & External Recon:** Used SpiderFoot to map external attack surface of 10+ partner organisations - identified 25+ shadow IT assets and exposed subdomains feeding directly into scoped offensive engagements; reduced unmonitored external attack surface by ~40% post-remediation.

COMPLIANCE, AUTOMATION & SIEM

- **Compliance Audits - Delivered & Closed:** Owned 8 end-to-end security audits (PCI DSS v4.0.1, ISO 27001:2022, SOC 2 Type 2, UIDAI AUA/KUA, NPCI, UCO Bank, Bank of Baroda, Axis Bank, Kotak Mahindra, BoM, BoI, NSDL, Slice) framed all findings from an attacker perspective with exploit narratives, remediation playbooks, and evidence packs; achieved full closure for every engagement with zero non-conformance carry-overs.
- **Security Automation:** Built Python, Bash, and Google Apps Script pipelines (JIRA REST API) to automate VAPT ticket tracking, risk dashboards, and SLA breach alerts - improved high-risk finding closure rates by 35% and reduced manual reporting effort by ~8 hours/week.
- **SIEM Deployment & Tuning - Wazuh:** Implemented Wazuh SIEM from scratch for centralised monitoring across endpoints, cloud services, and network devices - authored 20+ custom detection rules reducing false-positive alert volume by 45% while increasing true-positive detection rate; tuning insights fed directly into red-team stealth and evasion techniques for subsequent engagements.

TECHNICAL SKILLS

Primary Tooling	Burp Suite Pro (intercept, Intruder, Repeater, Scanner, Extensions), Nessus (vulnerability scanning, CVE triage, compliance checks)
Web & API Testing	OWASP Top 10 & API Top 10, session management, auth/authz bypass, injection (SQL/XSS/XXE/SSTI), SSRF, CSRF, insecure deserialization, business logic abuse, TLS/cipher review, Postman, OWASP ZAP
Mobile Security	Android VAPT, APK analysis, certificate pinning bypass, traffic interception, insecure storage, Frida, MobSF
VAPT Toolchain	Metasploit, Nmap, SQLMap, Nuclei, Subfinder, Ffuf, Gobuster, Acunetix, Nikto, Hydra, Hashcat, John the Ripper, BeEF, Aircrack-ng
Cloud & Containers	GCP SCC, AWS Security Hub, Kubernetes (GKE) hardening, Docker image security, CIS Benchmarks, misconfiguration discovery & exploitation
Network & Wireless	Network enumeration, pivoting, firewall/ACL bypass, VPN & segmentation testing, 802.11 security, WPA2/WPA3 attacks, rogue AP
SIEM & Monitoring	Wazuh (custom rules, deployment), Zabbix anomaly detection, log analysis, detection-evasion awareness
Scripting	Python 3.x, Bash, PowerShell, Google Apps Script, REST API integration, custom recon/scanning/reporting automation

Frameworks	OWASP Testing Guide, PTES, MITRE ATT&CK, NIST CSF, CIS Benchmarks, PCI DSS v4.0.1, ISO 27001:2022, SOC 2 Type 2, RBI/NPCI/UIDAI guidelines
Platforms & OS	Kali Linux, Parrot OS, Ubuntu

CERTIFICATIONS

- eJPT v2 - eLearnSecurity Junior Penetration Tester
- Practical Ethical Hacker (PEH) - TCM Security
- INE Certified Cloud Associate (ICCA) - INE Security
- Cisco CyberOps Associate - Cisco Systems
- Ethical Hacking Essentials (EHE) - EC-Council
- Network Defence Essentials (NDE) - EC-Council
- Digital Forensics Essentials (DFE) - EC-Council
- Basic to Advanced Kali Linux - CRAW Security
- Cybersecurity Essentials - Cisco
- PCAP - OpenEDG Python Institute
- CCNA v1.7 - Cisco Certified Network Associate

AWARDS

iServeU Technology Pvt. Ltd. · Bhubaneswar, India

Dec 2023 – Present

- Best Intern Award, 2024
- Rising Performer Award, 2025

EDUCATION

Bachelor of Technology Graduation- Computer Science & Engineering

2020 – 2024

Veer Surendra Sai University of Technology (VSSUT), Bhubaneswar, India

Intermediate +2 science- (Computer Science as elective)

2018 – 2020

DAV Public School Pokhariput, Bhubaneswar, India

Matriculation- (Computer Science as elective)

2008 – 2018

Saint Lawrence School, Angul, India
